

## SESIÓN NORMATIVAS CLAVE PARA LA SEGURIDAD DE LA NUBE

### CONTENIDOS:

- GDPR (reglamento general de protección de datos).
  - Introducción, propósito y alcance.
  - Principios claves.
  - Impacto en la nube y multas.
- HIPAA (health insurance portability accountability act)
  - Propósito.
  - Principales normativas.
  - Aplicación en la nube.
- PCI-DSS (payment card industry data security standard)
  - Descripción general.
  - Requisitos clave de la normativa.
  - Impacto en la nube.
- ISO/IEC 27001 (sistema de gestión de seguridad de la información):
  - Alcance y estructura.
  - Aplicación en la nube.
  - Certificación iso27001.
- Impacto del cumplimiento normativo.

### SEGURIDAD CLOUD: NORMATIVAS CLAVE

#### Introducción

La seguridad en la nube es una prioridad para las empresas que manejan datos sensibles. Las normativas de seguridad establecen requisitos específicos para proteger los datos y garantizar su integridad, privacidad y disponibilidad en entornos de nube. A continuación, revisaremos las principales normativas y su impacto en la nube.

#### GDPR (REGLAMENTO GENERAL DE PROTECCIÓN DE DATOS)

## Introducción, Propósito y Alcance

El GDPR, introducido en 2018 por la Unión Europea, regula el procesamiento de datos personales y protege los derechos de los ciudadanos de la UE en torno a su privacidad y libertad. Abarca cualquier organización que recopile, almacene o procese datos de personas en la UE, incluso si la empresa se encuentra fuera de esta región. Esto incluye datos de clientes, empleados, y otros individuos.



Ilustración 1 GDPR

## Principios Claves del GDPR

1. Legalidad, lealtad y transparencia: Los datos deben ser recopilados y gestionados legalmente y de manera transparente para las personas afectadas.
2. Limitación de propósito: Los datos solo deben utilizarse para propósitos específicos y claramente establecidos.
3. Minimización de datos: Solo se deben recopilar datos que sean necesarios para el propósito específico.
4. Exactitud: Los datos deben ser precisos y mantenerse actualizados.
5. Limitación de conservación: Los datos no deben conservarse por más tiempo del estrictamente necesario.
6. Integridad y confidencialidad: Los datos deben protegerse contra accesos no autorizados y procesamiento indebido.

Impacto en la Nube y Multas

Para cumplir con GDPR, las organizaciones deben asegurarse de que sus proveedores de servicios en la nube también cumplan con las normativas de protección de datos. Esto puede incluir cláusulas de seguridad adicionales y la posibilidad de realizar auditorías. Las multas por incumplimiento de GDPR son significativas: hasta el 4% de la facturación anual global de la empresa o 20 millones de euros, el monto que sea mayor.

## **HIPAA (HEALTH INSURANCE PORTABILITY AND ACCOUNTABILITY ACT)**

### **Propósito**

La HIPAA, promulgada en 1996 en los Estados Unidos, establece requisitos para proteger la información de salud personal (PHI) de los pacientes, con el objetivo de garantizar la confidencialidad, integridad y disponibilidad de los datos de salud. Es especialmente relevante para entidades de salud y sus socios comerciales que procesan información médica, tanto en sistemas locales como en la nube.



*Ilustración 2 HIPAA*

### **Principales Normativas**

1. Regla de Privacidad: Protege la información de salud de los pacientes y otorga derechos de acceso y control a los individuos sobre sus datos personales.
2. Regla de Seguridad: Exige medidas de protección para garantizar la confidencialidad, integridad y disponibilidad de la información médica.

3. Regla de Notificación de Violaciones: Obliga a notificar a los individuos y a las autoridades en caso de violación de seguridad que afecte a la información médica.

### **Aplicación en la Nube**

Las organizaciones que manejan información de salud deben asegurar que sus proveedores de servicios en la nube cumplan con HIPAA. Esto se logra mediante acuerdos de socio comercial (Business Associate Agreements, BAA) que establecen protocolos de seguridad, responsabilidad compartida y políticas específicas para proteger los datos en la nube.

### **PCI-DSS (PAYMENT CARD INDUSTRY DATA SECURITY STANDARD)**

El PCI-DSS es un conjunto de normas desarrollado para asegurar la protección de la información de las tarjetas de pago, aplicable a cualquier entidad que maneje, almacene o transmita datos de tarjetas de crédito y débito. Este estándar fue creado por el Consejo de Normas de Seguridad de la Industria de Tarjetas de Pago para reducir el fraude y proteger a los consumidores y las empresas mediante prácticas rigurosas de seguridad.



*Ilustración 3 PCI DSS*



### **Requisitos Clave de la Normativa**

1. Construir y Mantener una Red Segura: Requiere el uso de firewalls y configuraciones de seguridad para proteger la red.
2. Proteger los Datos del Titular de la Tarjeta: Incluye cifrado de datos y almacenamiento seguro para evitar el acceso no autorizado.
3. Mantener un Programa de Gestión de Vulnerabilidades: Abarca el uso de antivirus y la aplicación regular de actualizaciones de software para minimizar las vulnerabilidades.
4. Controlar el Acceso a la Información: Implementación de políticas que restringen el acceso a la información solo a quienes realmente la necesitan para sus funciones.
5. Monitorear y Probar Redes: Exige auditorías y revisiones de seguridad regulares para identificar y corregir posibles brechas de seguridad.
6. Mantener una Política de Seguridad: Involucra la documentación y aplicación de políticas para gestionar la seguridad de la información.

### **Impacto en la Nube**

El cumplimiento de PCI-DSS en un entorno de nube requiere elegir proveedores que cumplan con los estándares PCI-DSS y garantizar configuraciones seguras en el entorno en la nube. Esto implica trabajar en colaboración con el proveedor para asegurar que se mantenga la integridad y seguridad de los datos de tarjetas, y que se realicen auditorías y revisiones regulares.

## ISO/IEC 27001 (SISTEMA DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN)

### Alcance y Estructura

ISO/IEC 27001 es una norma internacional que proporciona un marco para la implementación y gestión de la seguridad de la información en una organización. Esta norma identifica los riesgos potenciales para la información y establece controles específicos para asegurar que los datos estén protegidos. ISO/IEC 27001 está estructurada en varias secciones que incluyen políticas, procesos, procedimientos, estructuras organizativas y funciones, todas orientadas a la seguridad de la información.



*Ilustración 4 ISO/IEC 27001*

### Aplicación en la Nube

ISO/IEC 27001 es altamente relevante para la seguridad en la nube, ya que permite a las organizaciones aplicar una gestión coherente de los riesgos de seguridad en el entorno en la nube. Los proveedores de servicios en la nube que están certificados bajo esta norma demuestran que aplican controles de seguridad específicos, protegiendo adecuadamente los datos de los clientes. Esto ofrece una capa adicional de confianza a las empresas que utilizan estos servicios, ya que asegura prácticas de seguridad verificadas.



## **Certificación ISO 27001**

La certificación ISO 27001 es ampliamente reconocida a nivel mundial y valida que una organización ha implementado un sistema de gestión de seguridad de la información efectivo. Contratar servicios en la nube de proveedores con certificación ISO 27001 proporciona a las organizaciones la garantía de que se siguen buenas prácticas de seguridad y que los datos serán gestionados en cumplimiento con estándares internacionales.

## **IMPACTO DEL CUMPLIMIENTO NORMATIVO**

El cumplimiento de normativas de seguridad en la nube no solo protege a las organizaciones de posibles sanciones legales y financieras, sino que también desempeña un papel fundamental en la construcción de una reputación de confianza y profesionalismo. La implementación de regulaciones como GDPR, HIPAA, PCI-DSS e ISO 27001 permite a las organizaciones demostrar su compromiso con la protección de la información de los clientes y la integridad de sus operaciones.

Adherirse a estas normativas proporciona beneficios clave:

- **Reducción de Riesgos de Seguridad:** Cumplir con estas regulaciones reduce la probabilidad de incidentes de seguridad graves, como violaciones de datos y accesos no autorizados.
- **Mejora de Resiliencia Operativa:** Al aplicar buenas prácticas de seguridad, las organizaciones logran una mayor capacidad de recuperación ante desastres y continuidad de sus operaciones en la nube.
- **Ventaja Competitiva:** Los clientes y socios comerciales valoran cada vez más a las empresas que demuestran un compromiso sólido con la seguridad de la información, lo que puede convertirse en un diferenciador en mercados competitivos.
- **Cumplimiento Global y Expansión:** Muchas normativas, como el GDPR y la ISO 27001, facilitan la expansión en mercados internacionales al asegurar que los datos se manejan de manera segura y conforme a regulaciones internacionales.

En un entorno donde los riesgos de ciberseguridad y las expectativas de los consumidores sobre la protección de datos son crecientes, el cumplimiento normativo en la nube es esencial para la sostenibilidad y crecimiento de las organizaciones.